

Dev Sec Audit

L'audit de sécurité web qu'un chef d'entreprise peut lire.

Saisissez un domaine. Obtenez un score, une note de A à F, chaque problème en langage clair et les étapes exactes pour le corriger.

Présentation produit · Septembre 2026

Le problème

- Les petites entreprises vivent sur un site créé par une agence ou un freelance, que plus personne ne vérifie ensuite.
- Les scanners existants parlent aux ingénieurs : en-têtes bruts, numéros de CVE, ni priorités ni consignes.
- La protection gérée nettoie les malwares après coup, pour 230 à 550 \$ par an et par site, sans expliquer le risque.
- Le propriétaire finit sans rien, ou avec un rapport inexploitable.

Ce que fait DevSecAudit

Il examine le site de l'extérieur, comme le ferait un attaquant, puis transforme ce qu'il trouve en une page qu'un non-technicien peut exploiter, ou transmettre à la personne qui s'occupe du site.

À qui il s'adresse

Premier acheteur visé : les petites agences web et freelances

Ils entretiennent plusieurs sites clients, savent appliquer un correctif et doivent montrer un travail continu. Le produit leur donne le constat, la re-vérification et le rapport client. Le français ouvre les agences francophones.

22

contrôles de sécurité

15

outils open source et

Ensuite : les chefs de petites entreprises

Veulent savoir si leur site est sûr, en mots qu'ils comprennent, et quoi demander à leur développeur.

Canal de distribution

Paielements et connexion via Whop : vente en direct et dans des communautés d'entrepreneurs.

0–100

score avec une note de

205

tests automatisés, tous3 / 30

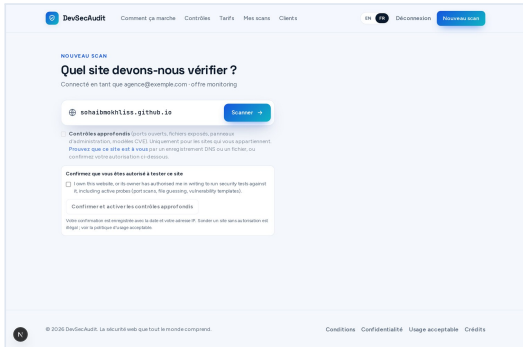
Ce que vit le client

1. **Connexion** avec Google, Whop ou e-mail. Chaque utilisateur a un compte.
2. **Saisie du domaine.** Les contrôles approfondis s'activent quand la propriété du site est vérifiée ou quand le client a enregistré une autorisation écrite pour ce site. Payer ne donne jamais le droit de sonder.
3. **Suivi en direct.** Chacun des 22 contrôles se coche à mesure qu'il se termine, avec les constats déjà trouvés.
4. **Lecture du rapport.** Score, note, constats du plus grave au plus bénin, correctifs, contrôles effectués.
5. **Correction.** Copier un prompt prêt à l'emploi dans Claude ou ChatGPT, télécharger le PDF, ou l'envoyer à un développeur.
6. **Correction vérifiée.** Chaque constat devient un problème suivi ; un re-test ciblé ne le marque corrigé que lorsque son contrôle, exécuté en entier, ne le trouve plus.

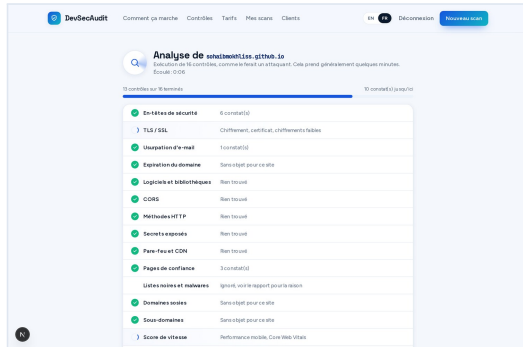
La page d'accueil



Lancer un scan et le suivre en direct

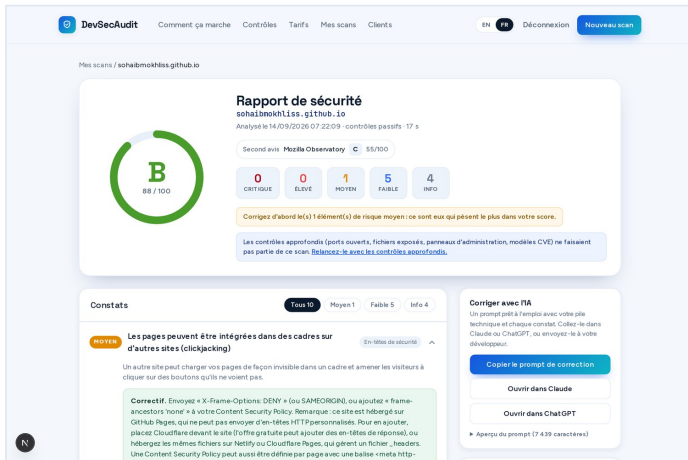


Les contrôles approfondis s'activent d'eux-mêmes quand le compte y a droit.



Chaque contrôle remonte son résultat dès qu'il termine ; la page se met à jour seule.

Le rapport



Constats, correctifs et prompt IA

 DevSecAudit

[Comment ça marche](#) [Contrôles](#) [Tarifs](#) [Mes scans](#) [Clients](#)

EN FR [Déconnexion](#) [Nouveau scan](#)

hébergez les mêmes fichiers sur Netlify ou Cloudflare Pages, qui gèrent un fichier `_headers`. Une Content Security Policy peut aussi être définie par page avec une balise `<meta http-equiv="Content-Security-Policy">`, mais `frame-ancestors` y est ignoré.

hosting platform: `GitHub Pages`

FAIBLE

HSTS ne couvre pas les sous-domaines

En-têtes de sécurité

Les sous-domaines (par exemple `admin.votredomaine.com`) ne sont pas protégés par la politique et restent joignables en HTTP non chiffré.

Correctif. Ajoutez `<includeSubDomains>` à l'en-tête `Strict-Transport-Security` une fois que tous les sous-domaines gèrent HTTPS. Remarque : ce site est hébergé sur GitHub Pages, qui ne peut pas envoyer d'en-têtes HTTP personnalisés. Pour en ajouter, placez Cloudflare devant le site (l'offre gratuite peut ajouter des en-têtes de réponse), ou hébergez les mêmes fichiers sur Netlify ou Cloudflare Pages, qui gèrent un fichier `_headers`. Une Content Security Policy peut aussi être définie par page avec une balise `<meta http-equiv="Content-Security-Policy">`, mais `frame-ancestors` y est ignoré.

header: `max-age=31556952` hosting platform: `GitHub Pages`

FAIBLE

Aucune Content Security Policy

En-têtes de sécurité

FAIBLE

Les navigateurs peuvent deviner le type des fichiers (MIME sniffing)

En-têtes de sécurité

FAIBLE

Aucun en-tête Referrer-Policy

En-têtes de sécurité

FAIBLE

Aucune page de politique de confidentialité trouvée

Pages de confiance

INFO

Aucun en-tête Permissions-Policy

En-têtes de sécurité

Hébergé sous un domaine de plateforme (`github.io`) : le DNS

Rapport PDF

Le rapport complet sous forme de fichier, à conserver ou à remettre à la personne qui s'occupe du site.

Télécharger le PDF

Suivre les corrections

Chaque constat devient un problème du site jusqu'à ce qu'un re-test prouve qu'il est corrigé.

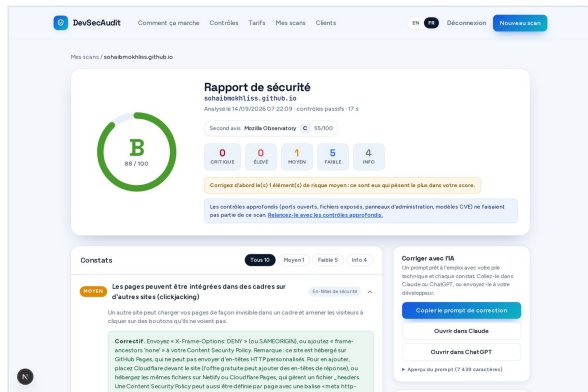
Ouvrir la liste des problèmes

Contrôles effectués

12 sur 16 exécutés

En-têtes de sécurité	6
TLS / SSL	0
Usurpation d'e-mail	1
Expiration du domaine	S.O.
Logiciels et bibliothèques	0
CORS	0
Méthodes HTTP	0
Secrets exposés	0

Deux langues, au choix de l'utilisateur



Le même rapport en français : constats, correctifs, prompt IA et PDF.

Un bouton EN / FR dans la barre de navigation ; le choix est mémorisé sur le compte et suit l'utilisateur jusque dans ses e-mails.

Tout est traduit

- Le site entier, pages légales comprises
- Les constats et correctifs des 22 contrôles
- Le PDF et le prompt IA (qui répond en français)
- Les e-mails de surveillance

Le français est rendu à la lecture depuis un catalogue de 390 phrases et 70 modèles : un scan existant change de langue instantanément, sans coût par scan.

Comment fonctionne un scan

Contrôles passifs (15)

Ne lisent que ce qu'un visiteur peut voir : en-têtes, certificats, DNS, code source, bases publiques. Sur n'importe quel site.

Contrôles approfondis (6)

Sondent activement : fichiers exposés, panneaux d'administration, ports, modèles de vulnérabilités, scanner de serveur.

Uniquement sur les sites dont la propriété est prouvée, ou sur offre payante.

La propriété est vérifiée par un enregistrement DNS ou un fichier sur le site : la garantie juridique, qui débloque les contrôles approfondis. Une agence qui ne gère pas le DNS de son client enregistre à la place une autorisation écrite, horodatée et

Règles d'honnêteté

- Un contrôle qui ne peut pas s'exécuter le dit, avec la raison : quota, clé manquante, bloqué par un pare-feu, délai dépassé. Il n'est jamais présenté comme « sain ».
- Un rapport avec des contrôles ignorés est marqué partiel.
- Les pages de défi Cloudflare et Vercel sont reconnues : un défi n'est jamais noté comme s'il s'agissait du site.

Les 22 contrôles et les outils derrière (1/3)

Contrôle	Ce qu'il recherche	Outil ou source
En-têtes de sécurité	HSTS, CSP, clickjacking, MIME sniffing, referrer policy, redirection HTTPS, attributs des cookies	Client HTTP maison; second avis de Mozilla Observatory
TLS / SSL	Versions du protocole, chiffrements faibles, validité du certificat, failles TLS connues	sslyze
Usurpation d'e-mail	SPF, DMARC, DKIM, MX, CAA, DNSSEC, MTA-STS, BIMI	dnspython, résolveurs publics
Expiration du domaine	Compte à rebours, verrou de transfert, registrar	RDAP
Logiciels et bibliothèques	CMS, framework, bibliothèques JavaScript, versions obsolètes ou vulnérables	Chromium headless (Playwright)
CORS	Origines reflétées, accès inter-origines avec identifiants	Sondes maison
Méthodes HTTP	TRACE et verbes dangereux	Sondes maison
Secrets exposés	Clés d'API, clés privées, jetons, e-mails dans le code et les scripts	Détection de motifs maison

Les 22 contrôles et les outils derrière (2/3)

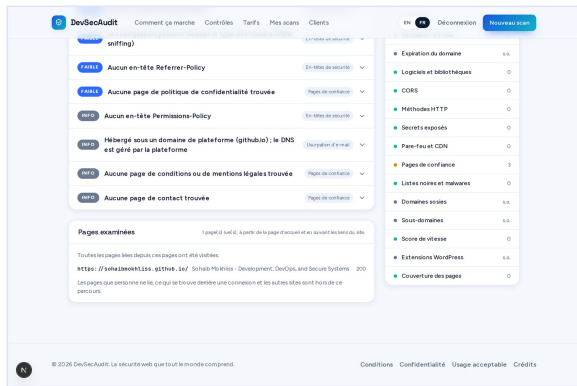
Contrôle	Ce qu'il recherche	Outil ou source
Pare-feu et CDN	Quel CDN ou WAF est en frontal, scripts tiers	Signatures d'en-têtes et de serveurs de noms
Pages de confiance	Politique de confidentialité, CGU, page contact, bandeau cookies	Crawler maison
Listes noires et malwares	Le domaine est-il signalé pour malware ou hameçonnage	URLhaus, Google Safe Browsing, VirusTotal
Domaines sosies	Typosquats enregistrés pouvant usurper la marque	dnstwist
Sous-domaines	Environnements de test oubliés, DNS orphelins exposés à un détournement	Journaux de certificats (crt.sh, Cert Spotter)
Score de vitesse	Performance mobile, Core Web Vitals	Google PageSpeed Insights
Extensions Word-Press	Extensions et thèmes aux vulnérabilités connues	API WPScan
Couverture des pages	Parcours borné des pages publiques : formulaires non chiffrés, contenu mixte, en-têtes présents sur l'accueil mais absents ailleurs	Crawler maison, robots.txt respecté

Les 22 contrôles et les outils derrière (3/3) : contrôles approfondis

Contrôle		Ce qu'il recherche	Outil ou source
Fichiers exposés		.env, .git, sauvegardes, exports de base de données, journaux	Sondes maison
Exposition	Word-Press	Énumération d'utilisateurs, XML-RPC, divulgation de version	Sondes maison
Panneaux	d'administration	Pages de connexion et phpMyAdmin accessibles depuis internet	Sondes maison
Ports ouverts		Services et bases de données exposés	nmap
CVE connues		Vulnérabilités précises, mauvaises configurations, identifiants par défaut	Nuclei, 13 000 modèles communautaires
Scanner de serveur		Fichiers dangereux, applications d'exemple, logiciel serveur obsolète	Nikto

Réservés aux sites dont la propriété est vérifiée ou pour lesquels une autorisation a été enregistrée ; le paiement seul ne suffit pas. Chaque source est surveillée par une sonde périodique ; les échecs temporaires sont relancés.

Ce que le produit refuse de dire



- Un contrôle qui n'a pas pu s'exécuter **le dit**, avec sa raison : quota, clé absente, pare-feu, délai dépassé, outil en erreur. Le rapport est marqué partiel.
- Un constat n'est **corrigé** que si le test a ré-examiné la ressource concernée. Page en 403, disparue de la navigation, exclue par robots.txt : le constat reste *non vérifié*.
- La **couverture est annoncée** : les pages lues, et ce qui a été écarté, avec la raison.

La sécurité de la plateforme elle-même

Le scanner ne sort que vers internet

Chaque requête, chaque redirection et chaque requête du navigateur sans interface est vérifiée contre les adresses privées, de bouclage, de lien local et de métadonnées cloud. Les redirections ne sont plus suivies automatiquement : chaque saut est validé avant d'être récupéré.

L'autorisation n'est pas à vendre

Les contrôles actifs exigent une propriété vérifiée ou une autorisation enregistrée, horodatée et conservée. Payer ne donne jamais le droit de sonder.

Le chemin de l'argent est ennuyeux

Seuls les événements documentés agissent ; le corps brut est vérifié par signature ; un même paiement livré deux fois n'accorde qu'un crédit ; un remboursement met fin à l'accès qu'il avait payé.

Rien ne bouge sans consentement

Une invitation ne fait rejoindre personne : elle attend un lien à usage unique, accepté depuis le compte concerné. Les signaux anti-abus sont effacés au bout de 90 jours, comme promis.

Le score

Chaque constat a une gravité et un poids.
Les constats identiques ne comptent qu'une fois, les pénalités d'un même contrôle décroissent pour qu'une seule faiblesse ne coule pas tout le score, et les éléments informatifs sont gratuits.

CRITIQUE 30 **ÉLEVÉ** 15 **MOYEN** 7
FAIBLE 2 **INFO** 0

Notes : **A** ≥ 90 **B** ≥ 80 **C** ≥ 65 **D** ≥ 50

Les éléments hors sécurité, comme la vitesse ou l'absence de politique de confidentialité, sont volontairement en gravité faible : ils informent sans dominer.

Calibré sur de vrais sites

Site	Score	Note
stripe.com	94	A
bankofamerica.com	84	B
github.com	79	C
example.com	62	D

Stripe est durci sur tous les plans. GitHub perd des points parce que les flux de malwares listent des fichiers hébergés chez lui. example.com accepte encore TLS 1.0 et des chiffrements faibles, sans HSTS.

Le rapport PDF



Généré côté serveur, sans dépendre d'une session de navigateur.

- Score, note, répartition par gravité
- Chaque constat avec son correctif
- Contrôles effectués et ceux qui n'ont pas pu l'être
- Le prompt IA complet

Réservé aux offres payantes.

Préparé par Agence Démo avec DevSecAudit (https://demo.devsecaudit.com/). Les constatés découlent de ce que l'état observable de l'interface du navigateur du scanner et ne garantissent pas l'absence d'autres problèmes.

Le prompt IA de correction

Plutôt que d'appeler un modèle d'IA aux frais du produit, le rapport génère un prompt précis : la pile technique détectée, la plateforme d'hébergement, chaque constat avec ses preuves, et la consigne de fournir les changements de configuration exacts pour cette pile.

Le client le colle dans l'IA qu'il utilise déjà, avec des liens en un clic vers Claude et ChatGPT.

Pourquoi c'est important

- Aucun coût d'IA par scan
- Aucun fait inventé sur le site : le prompt transporte les preuves
- Des correctifs écrits pour la vraie plateforme (un site GitHub Pages reçoit des consignes Cloudflare ou Netlify, pas Apache)

Surveillance et historique

The screenshot shows the DevSecAudit web application. At the top, there's a navigation bar with the logo, user name 'DevSecAudit', and links for 'Comment ça marche', 'Contrôles', 'Tarifs', 'Mes scans', and 'Clients'. On the right, there are language selectors for 'EN' and 'FR', a 'Déconnexion' button, and a 'Nouveau scan' button.

The main section is titled 'Mes scans' with the subtitle 'offre monitoring'. It features a 'Clients' tab and a 'Nouveau scan' button. Below this, there's a list of monitored sites with their status and scan frequency:

- newclient-demo.example**: Autorisé, aucun scan pour l'instant, Problèmes. ☐ Surveiller chaque semaine
- france-telephone.com**: Vérifier la propriété, 1 scan pour l'instant, Problèmes. ☐ Surveiller chaque semaine
- clickup.com**: Vérifier la propriété, 1 scan pour l'instant, Problèmes. ☐ Surveiller chaque semaine
- sohaibmokhliss.github.io**: Vérifier la propriété, 50, Problèmes. ☒ Surveillance - prochain scan le 21/09/2026
- gestioncolairepro.app**: Vérifier la propriété, 1 scan pour l'instant, Problèmes. ☐ Surveiller chaque semaine
- acquiscan.com**: Autorisé, -2, Problèmes. ☒ Surveillance - prochain scan le 21/09/2026

Below the list is a table showing the scan history:

SITE	NOTE	SCORE	STATUT	QUAND	
sohaibmokhliss.github.io	B	88	Terminé	17/09/2026 15:17:18	Voir
acquiscan.com	F	44	Terminé	15/09/2026 11:09:26	Voir
sohaibmokhliss.github.io	B	88	Terminé	14/09/2026 08:50:22	Voir
sohaibmokhliss.github.io	B	88	Terminé	14/09/2026 07:34:15	Voir
sohaibmokhliss.github.io	B	88	Terminé	14/09/2026 07:31:18	Voir

- Scan complet hebdomadaire par site, activé d'un simple interrupteur
- Contrôle léger quotidien entre deux : en-têtes, certificat, DNS, réputation
- Comparaison limitée aux contrôles réellement exécutés : rien n'est déclaré corrigé par hasard
- Alerte seulement sur un changement qui compte : 19/30

Vue opérateur : santé des sources

The screenshot displays the 'Santé des sources' (Source Health) section of the DevSecAudit interface. At the top, a navigation bar includes the DevSecAudit logo, links for 'Comment ça marche', 'Contrôles', 'Tarifs', 'Mes scans', and 'Clients', along with user status 'EN' and 'DE', a 'Déconnexion' button, and a 'Nouveau scan' button. The main heading 'Santé des sources' is followed by the subtitle 'Chaque contrôle et source externe, sur les 24 dernières heures.' and a 'Lancer la sonde maintenant' button. A status bar indicates 'Degradé' with a warning icon and '1 à surveiller : reputation'. Below this, a table titled 'Contrôles et sources' lists various checks and their status. To the right, an 'Alertes récentes' section shows 'Aucune alerte sur cette période.'

NOM	SANTÉ	EXÉCUTIONS	ÉCHECS	RAISONS
cors	Ok	1	0	—
crawl	Ok	1	0	—
dns	Ok	1	0	—
domain	Ok	1	0	—
edge	Ok	1	0	—
fingerprint	Ok	1	0	—
headers	Ok	1	0	—
http_methods	Ok	1	0	—
leaks	Ok	1	0	—
localities	Ok	1	0	—

Chaque contrôle et chaque source externe sur les vingt-quatre dernières heures : santé, exécutions, échecs et raison de l'échec.

Du constat à la correction vérifiée

The screenshot displays the DevSecAudit application interface. At the top, there's a navigation bar with 'DevSecAudit', 'Comment ça marche', 'Contrôles', 'Tarifs', 'Mes scans', 'Clients', and a language selector (EN, FR) with a 'Déconnexion' button. A 'Nouveau scan' button is also present.

The main content area is titled 'En cas de doute, commencez avec un max-age court (ex. 300) pendant une journée, puis augmentez-le.' Below this, there are tabs for 'Cloudflare (devant le site)', 'Nginx', and 'Apache (l'access)'. The 'Cloudflare' tab is active.

ETAPES

1. Dans le tableau de bord Cloudflare, ouvrez SSL/TLS → Edge Certificates → HTTP Strict Transport Security (HSTS).
2. Activez HSTS, mettez Max-Age à 12 mois et cochez Apply HSTS policy to subdomains (seulement si tous les sous-domaines sont en HTTPS).
3. Enregistrez. Cloudflare ajoute l'en-tête ci-dessous à chaque réponse HTTPS.

A 'Copier' button is next to the generated header: `Strict-Transport-Security: max-age=31536000; includeSubDomains`.

RIQUEUSE CHOSE CASSE

- Les navigateurs qui ont déjà vu l'en-tête continuent d'imposer HTTPS jusqu'à la fin du max-age. Pour annuler plus tôt, servez max-age=0 aussi longtemps que le max-age initial, puis retirez l'en-tête.

VÉRIFICATION

Le nouveau test demande la page d'accueil en HTTPS et vérifie l'en-tête, son max-age et includeSubDomains.

A 'Vérifier le correctif' button is shown, with a note: 'Relance uniquement le contrôle de ce problème et le marque corrigé si le problème a disparu.'

On the right side, there are buttons for 'Enregistrer', 'Risque accepté', and 'Pas un problème ici'.

Below, there's a list of issues, all marked as 'FAIBLE' (Low) risk:

- ☐ **FAIBLE** Aucune Content Security Policy ouvert En-têtes de sécurité
- ☐ **FAIBLE** Aucune page de politique de confidentialité trouvée ouvert Pages de confiance
- ☐ **FAIBLE** Aucun en-tête Referrer-Policy pas un problème En-têtes de sécurité

A note at the bottom states: 'Un problème n'est marqué corrigé que lorsqu'un scan ayant exécuté son contrôle en entier ne le trouve plus. Si le contrôle a été ignoré ou interrompu, le problème reste non vérifié.'

Surveillance et alertes

Un scan complet chaque semaine, un contrôle léger chaque jour (en-têtes, certificat, DNS, réputation), et une alerte seulement quand quelque chose d'important change.

- ☒ **Surveillance active** - prochain scan complet le 21/09/2026
- ☒ **Contrôle léger quotidien**
Exécute chaque jour les contrôles passifs rapides; alerte seulement sur un nouveau problème grave, un souci de certificat ou de liste noire, ou une vraie baisse de score.

- Chaque constat devient un **problème suivi** : première apparition, dernière vérification, responsable, notes
- **Correctif guidé** par environnement (Cloudflare, Nginx, Apache, zone DNS) : prérequis, extrait à copier, **retour arrière**
- **Re-test ciblé** : un bouton relance le seul contrôle concerné
- **Corrigé** seulement si ce contrôle a tourné en entier sans le retrouver ; sinon, *non vérifié*

Espace agence : clients, équipe, portefeuille

The screenshot displays the 'DevSecAudit' web application interface. At the top, there's a navigation bar with links like 'Comment ça marche', 'Contrôles', 'Tarifs', 'Mes scans', and 'Clients'. A user profile 'EN' and a 'Déconnexion' button are on the right, along with a 'Nouveau scan' button. The main section is titled 'Portefeuille clients' with a subtitle 'Tous les sites dont vous vous occupez, regroupés par client, avec ce qui demande votre attention en premier.' Below this, a summary shows '6 site(s) - 2 problème(s) grave(s) ouvert(s) - 0 en retard - 3 avec une ouverture incomplète'. The interface is divided into three main panels. The left panel, 'Client Démo', lists three clients: 'acquiscan.com' (15/09/2026, 11 Ouverts, 2 Graves, En retard, Approfondi, partiel), 'clickup.com' (09/09/2026, Rien d'urgent, 0 Ouverts, 0 Graves, En retard, Approfondi, complet), and 'france-telephone.com' (09/09/2026, Rien d'urgent, 0 Ouverts, 0 Graves, En retard, Approfondi, complet). The middle panel, 'Clients', has a search bar and a 'Ajouter un client' button. The right panel, 'Équipe', shows 'Propriétaire de l'espace : agence@exemple.com' with an 'Inviter' button. Below it, 'COÉQUIPIERS' section is empty. The bottom right panel, 'Marque des rapports', shows 'Affichée en haut de chaque rapport client', 'Nom de l'agence : Agence Démo', and a 'Logo (PNG, JPEG ou SVG)' section with a 'Choisir une image' button and an 'Enregistrer' button.

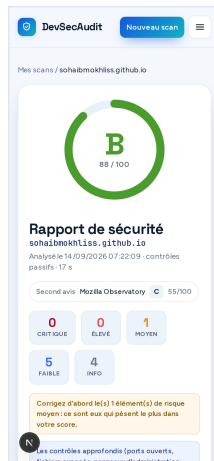
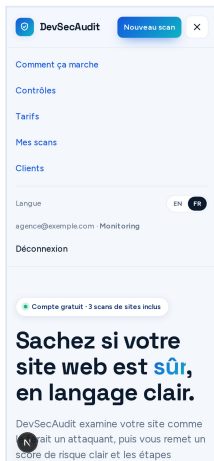
- Les sites se regroupent par **client**
- **Invitation d'un coéquipier** par e-mail : il rejoint l'espace seulement après avoir accepté depuis son propre compte, via un lien à usage unique qui expire ; il travaille ensuite sur les mêmes sites, la même offre, les mêmes crédits
- **Portefeuille** : par client, les problèmes graves ouverts, ceux qui traînent depuis plus de deux semaines, les corrections non vérifiées et les **trous de couverture**

Rapport client à la marque de l'agence



- Nom et logo de l'agence en tête du rapport
- **Résumé pour décideur** : où en est le site, ce qui a été corrigé et vérifié, ce qui a changé depuis le rapport précédent
- Problèmes ouverts du plus grave au plus bénin, puis les **corrections vérifiées**
- **Lien de partage** qui expire, révocable, sans compte à créer
- En ligne ou en PDF, en français ou en anglais

Fonctionne sur téléphone



Architecture

Frontend	Next.js 16 (React, TypeScript, Tailwind) : accueil, connexion, scan, suivi en direct, rapport, historique, tarifs, vérification de propriété, santé des sources, pages légales. Adapté jusqu'à la taille d'un téléphone.
API	Python FastAPI avec SQLAlchemy et migrations Alembic : comptes, règles des offres, file de scans, résultats, génération du PDF, surveillance, webhook Whop.
Workers	Des workers Celery sur Valkey exécutent les scans, deux à la fois chacun ; la capacité augmente en une commande. Un planificateur lance les scans hebdomadaires, les contrôles quotidiens, la sonde des sources et le ménage des scans abandonnés.
Données	PostgreSQL pour les comptes, les sites et les résultats bruts. Sauvegardes nocturnes conservées 14 jours.
Déploiement	Docker Compose derrière Caddy avec HTTPS automatique. Tourne sur un petit VPS. Rapport d'erreurs Sentry en option.
CLI	Le même moteur en ligne de commande : scan, une commande « doctor » qui teste chaque clé et quota, et le prompt de correction.

Offres et paiements

Gratuit — 0 \$

Pour essayer

- 3 sites, un scan chacun
- Score, note, chaque constat expliqué
- Contrôles approfondis et re-scans sur les sites dont la propriété est vérifiée

Audit détaillé — 29 \$

Paieement unique, un site,
30 jours

- Correctif pas à pas pour chaque constat
- Contrôles approfondis une fois le site vérifié ou l'autorisation confirmée
- Prompt IA de correction, rapport PDF
- Re-scans pendant 30 jours pour confirmer les corrections

Surveillance — 49 \$ / mois

Jusqu'à 5 sites surveillés,
soit moins de 10 \$ par site

- Tout l'Audit détaillé, sur tous ses sites
- Scan complet hebdomadaire et contrôle léger quotidien, jusqu'à 5 sites
- Alerte seulement quand quelque chose d'important change
- Espace client, équipe, rapports à la marque de

Sa place sur le marché

Segment	Prix typique	Ce que DevSecAudit fait autrement
Vérificateurs gratuits instantanés (Mozilla Observatory, SSL Labs, Sucuri SiteCheck)	Gratuit	Chacun ne couvre qu'une tranche : en-têtes, ou TLS, ou malware. DevSecAudit combine 22 contrôles et les explique ; il cite aussi la note de Mozilla en second avis.
Protection gérée (Sucuri, SiteLock)	230 à 550 \$ par an, ou 20 à 45 \$ par mois, par site	Un service différent, complémentaire : pare-feu préventif et nettoyage de malwares. DevSecAudit n'en fait pas ; il audite la posture (usurpation d'e-mail, expiration du domaine, sosies, exposition, pages de confiance) et suit les corrections.
Scanners professionnels (Pentest-Tools, HostedScan, Astra, Intruder)	39 à 190 \$ par mois pour 5 cibles	Les plus proches : HostedScan combine déjà plusieurs scanners open source avec planification et alertes. DevSecAudit se distingue par le langage clair, le suivi des corrections jusqu'à la re-vérification, et le rapport client, pour des agences plutôt que des équipes sécurité.

Exploitation et confiance

Santé des sources

Chaque clé d'API et chaque quota sont sondés régulièrement ; le quota restant s'affiche en direct et les échecs déclenchent une alerte Slack ou Discord. Les contrôles ignorés temporairement sont relancés.

Coûts de fonctionnement

Scanners open source sur le serveur du produit. Sources de données sur paliers gratuits aujourd'hui ; la page d'administration montre quand un palier devrait passer en payant.

Cadre juridique

CGU, politique de confidentialité, politique d'usage acceptable. Contrôles approfondis réservés aux sites vérifiés ou payants. Le scanner s'identifie et limite son volume de requêtes.

Périmètre, dit clairement

Il audite un site de l'extérieur, comme un attaquant le voit. Un bon score signifie que rien de visible ne cloche, pas une garantie. Derrière une protection anti-bot agressive, le rapport est partiel et le dit.

Où il peut aller ensuite

Court terme, petits chantiers

- Étiquettes OWASP et PCI sur les constats
- Un aperçu gratuit sans inscription : score et note seulement
- Parcours plus profond sur les gros sites : budget de pages ajustable selon l'offre
- Correctifs guidés pour d'autres environnements : WordPress, Shopify, Netlify, Vercel

Opportunités plus larges

- Offre agence packagée : l'espace, les rapports à la marque et les liens client existent déjà ; il reste à en faire une quatrième formule et à la tarifier
- API publique avec clés, pour partenaires et hébergeurs
- Offre en marque blanche pour agences web et hébergeurs

Pourquoi c'est défendable

Les outils sont open source. Le produit, c'est la couche au-dessus.

- La traduction en langage clair de 22 contrôles en une page qu'un propriétaire peut exploiter
- Un score calibré qui correspond à l'avis d'un expert, et l'honnêteté sur ce qui n'a pas pu être vérifié
- Des correctifs adaptés à la plateforme et un prompt IA sans coût
- Un modèle de compte, de propriété et de surveillance qui le rend vendable à des non-ingénieurs
- Un canal de distribution via des communautés de créateurs que les éditeurs de sécurité n'atteignent pas